

SCANNING

Scanning

Revision: 1 Last modified: 2026-06-06T00:00:00Z

qBittorrent-Fixed runs **seven scanners** that cover dependencies, static analysis, secrets, and quality gates. They all run locally (via scripts/scan.sh) and in CI (.github/workflows/security.yml).

Scanner	Surface	Invocation	Runs in
pip-audit	Python runtime deps	host	push, nightly, weekly
bandit	Python SAST	host (pip install 'bandit[toml]')	push, weekly
ruff	Python lint + ASYNC/S rules	host	every push
semgrep	Multi-language SAST (project + registry rules)	compose run-once	weekly, push on source change
trivy	FS CVE + misconfig + secret scan	compose run-once	weekly, push on deps
gitleaks	Secret scan (git history)	compose run-once	every push
snyk	Commercial dep + SAST (needs token)	compose run-once	weekly
sonarqube	Quality gate upload (needs token)	sonar-scanner (host)	weekly

Local run

```
# Run everything – non-interactive, will skip snyk/sonar if tokens
  are unset
./scripts/scan.sh --all

# Run a subset
./scripts/scan.sh pip-audit bandit ruff

# Compose-based scanners need the quality profile up:
$COMPOSE_CMD -f docker-compose.yml -f docker-compose.quality.yml \
  --profile run-once up --remove-orphans --abort-on-container-
  exit
```

Reports land in artifacts/scans/<UTC timestamp>/ as SARIF/JSON. CI uploads them to the GitHub Security tab.

Non-interactive invariants

scripts/scan.sh **never** prompts, reads stdin, escalates privileges, or calls sudo. tests/unit/test_scan_script_non_interactive.py guards the invariant; the CI syntax workflow enforces it.

Secrets

- SNYK_TOKEN — if unset, the snyk container exits 0 with a warning.
- SONAR_TOKEN / SONAR_HOST_URL — if unset, the sonar upload is skipped.
- .env and .env.* are gitignored; .gitignore.toml allowlists only the constitution-mandated admin:admin default.

Waivers

Any .snyk ignore, .trivyignore entry, or semgrep inline-disable **must** carry:

1. Finding ID / CVE / rule ID.
2. Reason.
3. Expiry date (# expires: YYYY-MM-DD).

tests/unit/test_scan_waivers_have_expiry.py (added in Phase 2) will fail on anything older than its expiry or missing the reason/expiry annotation.

Triage policy

- **Critical** → blocks merge; fix or file CVE-waiver PR same day.
- **High** → blocks release; fix in current sprint.
- **Medium** → tracked in `ISSUES.md`; fixed opportunistically.
- **Low/info** → documented, ignored unless it bleeds into higher.

Observability hooks

Prometheus + Grafana are part of the same docker-compose.`quality.yml` file under the observability profile. See [docs/OBSERVABILITY.md](#).